

NOVASHYLD TECHNOLOGIES

Cybersecurity Analyst Internship Program

TASK 1 — CYBERSECURITY BREACH CASE STUDY

The 2022 Uber Data Breach

A Case Study in MFA Fatigue, Social Engineering, and Privileged Credential Exposure

Prepared By :- **Vikram prajapat**

Cybersecurity Analyst Intern

Submission Date: [22-7-26]

NovaShyld Technologies

Internal Training & Development Division

Table of Contents

1. Executive Summary
2. Company Overview
3. Incident Overview
4. Attack Timeline
5. Root Cause Analysis
6. Technical Analysis
7. Business Impact
8. Lessons Learned
9. Recommendations
10. Conclusion
11. References
12. Evidence & Screenshots

Note: This case study is compiled entirely from publicly available reporting (company disclosures, journalism, and security-vendor analysis). Sections 3–6 clearly separate facts confirmed by Uber or law enforcement from inference and industry analysis.

1. Executive Summary

On September 15, 2022, Uber Technologies, Inc. suffered a significant internal network intrusion. An attacker later linked to the Lapsus\$ hacking collective gained access to Uber's corporate network by socially engineering an external contractor into approving a fraudulent multi-factor authentication (MFA) request — a technique widely referred to as "MFA fatigue" or "MFA bombing." Once inside the network, the attacker located a PowerShell script on an internal network share that contained hardcoded administrator credentials for Uber's privileged access management (PAM) platform. Using those credentials, the attacker escalated privileges and gained broad access to Uber's internal tools, including its Slack workspace, Google Workspace, Amazon Web Services (AWS) console, SentinelOne endpoint detection console, HackerOne bug-bounty administration console, and internal financial systems.

Uber confirmed the intrusion publicly within days and stated that, based on its investigation, no Uber, Uber Eats, or Uber Freight rider, driver, or courier account data appeared to have been accessed or exfiltrated. The attacker did, however, access internal Slack messages, financial reporting tools, and vulnerability reports submitted through Uber's bug-bounty program. Law enforcement in the United States and the United Kingdom investigated the incident, and UK authorities subsequently charged and convicted individuals connected to the Lapsus\$ group for this and related intrusions.

This case study is presented as beginner-friendly, fact-based training material for the NovaShyld Technologies Cybersecurity Analyst Internship. It draws exclusively on Uber's own public disclosures and reputable secondary reporting and security-vendor analysis, and it distinguishes clearly between confirmed facts and industry inference where the two diverge.

2. Company Overview

Attribute	Details
Company Name	Uber Technologies, Inc.
Industry	Technology / Ride-hailing, food delivery, and freight logistics
Headquarters	San Francisco, California, United States
Business Operations	Operates a global platform connecting riders with drivers (Uber), consumers with restaurants and couriers (Uber Eats), and shippers with carriers (Uber Freight), across ride-hailing, delivery, and logistics markets in dozens of countries
Scale	One of the world's largest gig-economy technology platforms, processing millions of trips and deliveries daily and handling large volumes of payment, location, and personal data across its consumer apps

Uber's importance as an organization, from a security perspective, comes from the scale and sensitivity of the data and systems it operates. Its platforms process real-time location data, payment information, and personal details for hundreds of millions of riders, drivers, couriers, and restaurant partners globally. Uber also relies on a large internal technology estate — cloud infrastructure, source-code repositories, financial systems, and internal collaboration tools — to run day-to-day operations. Because Uber is a widely recognized global brand with a large user base, any security incident involving the company draws significant public, media, and regulatory attention, making it a valuable and closely studied example for security training.

3. Incident Overview

The table below summarizes the core facts of the incident as confirmed by Uber's official public updates and corroborated by independent reporting.

Field	Details
Date of Attack	September 15, 2022 (initial compromise and lateral movement); publicly disclosed by Uber on September 15–16, 2022, with a detailed follow-up update on September 19, 2022
Attack Type	Social engineering (MFA fatigue / MFA bombing) leading to internal network compromise and privilege escalation via exposed credentials
Initial Access	Compromised credentials of an external contractor, reportedly obtained via a dark-web credential purchase and/or an SMS-based phishing ("smishing") message impersonating Uber IT support, combined with repeated MFA push notifications until the contractor approved one
Target	Uber's internal corporate network and associated tools (VPN, internal network shares, PAM system, cloud consoles, Slack, financial and bug-bounty platforms) — not Uber's public-facing rider/driver applications
Detection Method	The attacker self-disclosed the breach by posting a message in Uber's internal Slack channel and defacing an internal tool; this alerted Uber's security team, which was corroborated by public reporting from security researchers the attacker contacted directly

4. Attack Timeline

The sequence below reconstructs the publicly reported chronology of the attack, from initial access through Uber's recovery actions.

1. Initial Access

The attacker obtained valid VPN credentials belonging to an external Uber contractor, reportedly through a purchased dark-web credential set and/or a smishing message impersonating Uber IT support.



2. MFA Bypass (Social Engineering)

The stolen password alone was blocked by Uber's MFA. The attacker responded by repeatedly triggering push-based MFA prompts to the contractor's device for roughly an hour, then contacted the contractor over WhatsApp posing as Uber IT support and convinced them that approving one prompt would stop the notifications. The contractor approved a request, granting the attacker VPN access.



3. Internal Reconnaissance

Once on Uber's internal network via VPN, the attacker began scanning internal file shares and systems for further access opportunities.



4. Compromise / Privilege Escalation

The attacker discovered a PowerShell script on a network share containing hardcoded administrator credentials for Uber's privileged access management (PAM) platform (reported to be Thycotic). Using these credentials, the attacker gained administrative access to the PAM system and extracted secrets for numerous internal services.



5. Lateral Movement / Access to Secrets

With PAM-derived credentials, the attacker accessed a wide range of internal tools, reportedly including AWS, Google Cloud Platform, Google Workspace (GSuite), Slack, SentinelOne (EDR), OneLogin/DUO identity services, the HackerOne bug-bounty admin console, internal financial and expense tools, and internal code repositories.



6. Disclosure / Detection

The attacker posted a message in Uber's company-wide Slack channel announcing the breach and altered an internal website to display explicit content, which triggered Uber's internal security response. The attacker separately contacted external security researchers and journalists, who publicized details of the intrusion.

7. Containment & Recovery

Uber revoked or reset credentials for affected internal accounts, disabled or locked down affected internal tools and code repositories, engaged law enforcement (FBI, U.S. Department of Justice) and outside forensic investigators, and began a broader review of its identity and access management practices.

5. Root Cause Analysis

What vulnerability was exploited?

No software vulnerability (in the sense of a CVE or coding flaw) was exploited in this incident. Instead, the attacker exploited two process and configuration weaknesses: first, a human/procedural weakness in how MFA approvals were handled, which allowed a determined social-engineering campaign to bypass an authentication control that was technically functioning correctly; and second, a credential-hygiene weakness — hardcoded, plaintext administrator credentials for a privileged access management platform stored inside an automation script on a network share that was reachable once the attacker was on the internal network.

Why did the attack succeed?

The attack succeeded because each individual control that should have stopped it depended on a single point of failure that the attacker was able to defeat. MFA depended on the end user correctly recognizing and rejecting a social-engineering attempt under sustained psychological pressure; once that single human decision failed, the attacker had unrestricted VPN-level network access. From there, the absence of network segmentation meant the attacker could freely browse internal file shares as though already a trusted internal user. Finally, the presence of hardcoded, unencrypted administrator credentials in a script meant that reaching the PAM system required no further exploitation at all — simply finding the file was sufficient to obtain full administrative control of the organization's secrets vault, which by design held credentials for a very large number of other critical systems.

Which security controls failed?

Control	Intended Purpose	Why It Failed
Multi-Factor Authentication (push-based)	Prevent account takeover even if a password is compromised	Push-based MFA without number-matching or phishing-resistant verification can be defeated by repeated prompting combined with social engineering of the end user
Security Awareness Training	Enable staff/contractors to recognize and reject social-engineering attempts	The contractor was not equipped to recognize a sustained MFA-fatigue and impersonation attempt as malicious
Network Segmentation	Limit what an attacker can reach after obtaining basic network access	VPN access appears to have granted broad reachability to internal file shares, rather than being scoped to only the resources the contractor needed
Secrets Management	Ensure privileged credentials are never stored in plaintext or embedded in scripts	Administrator credentials for the PAM platform were hardcoded in a PowerShell script instead of being managed through a secure, rotated secrets mechanism
Privileged Access Management (PAM) Design	Act as a single, tightly controlled vault for secrets, reducing the number of ways secrets can be reached	Because so many downstream systems relied on the PAM platform, compromising its administrator credentials functioned as a single point of failure that exposed a very large number of otherwise-separate systems at once

6. Technical Analysis

Attack Vector

The primary attack vector was credential-based social engineering targeting a third-party contractor, rather than a technical exploit against Uber's software or infrastructure. This is consistent with the broader pattern of intrusions attributed to the Lapsus\$ group during 2021–2022, which favored social engineering, credential purchasing, and SIM-swapping over custom malware or zero-day exploits against companies including Microsoft, Okta, Nvidia, and Samsung.

Malware

Some reporting indicates the contractor's personal device may have been infected with information-stealing malware prior to the breach, which could explain how the attacker obtained the initial password; however, Uber's own public statements focused on the MFA-fatigue and social-engineering elements rather than confirming a specific malware family, so this detail should be treated as reported-but-not-confirmed rather than established fact.

Phishing

Reporting is split between two non-exclusive explanations for the initial credential theft: a purchased credential from a dark-web marketplace, and a smishing (SMS phishing) message in which the attacker, posing as Uber IT support, persuaded the contractor to disclose a password directly. Both mechanisms are plausible and not mutually exclusive, and the attacker's own account of the incident (shared with security researchers and journalists) leaned toward active social engineering rather than a purely passive credential purchase.

Exploited Vulnerability

As noted in Section 5, this incident did not involve a specific software vulnerability or CVE. The exploited weakness was procedural: hardcoded administrator credentials left in an accessible automation script, combined with a lack of restriction on what an authenticated VPN user could browse on internal network shares.

MITRE ATT&CK Techniques (Publicly Documented)

Multiple independent security-vendor writeups (including CyberArk, GitGuardian, and Procyon) have mapped this incident to the following publicly documented MITRE ATT&CK Enterprise techniques. This mapping is analysis performed by third-party researchers rather than an official attribution published by Uber or MITRE, and is presented here as commonly cited industry interpretation.

Tactic	Technique	ID	Relevance to This Incident
Initial Access	Phishing	T1566	Smishing message impersonating Uber IT support, used to obtain or reinforce the contractor's credentials
Credential Access	Multi-Factor Authentication Request Generation	T1621	Repeated push-notification prompts sent to the contractor's device to induce MFA approval ("MFA bombing")
Initial Access / Persistence	Valid Accounts	T1078	Use of the contractor's legitimate VPN credentials and, later, the PAM administrator account, to move through the environment as a trusted user
Discovery	Network Share Discovery	T1135	Browsing internal network shares after obtaining VPN access to locate further material
Credential Access	Unsecured Credentials: Credentials In Files	T1552.001	Hardcoded PAM administrator credentials found in a PowerShell script on a network share
Privilege Escalation / Credential Access	Steal Application Access Token / Credentials from Password Stores	T1528 / T1555	Use of PAM administrator access to retrieve stored secrets for numerous downstream services
Collection	Data from Information Repositories	T1213	Access to internal Slack messages and financial-tool data following privilege escalation

7. Business Impact

Financial Loss

Uber has not publicly disclosed a specific dollar figure directly tied to this 2022 incident, and no regulatory fine has been publicly confirmed specifically for it at the time of writing, distinguishing it from Uber's separate 2016 breach, which resulted in significant regulatory settlements. Indirect costs likely included incident response, forensic investigation, legal counsel, credential rotation across a large number of internal systems, and engineering time spent rebuilding trust in affected tools — costs that are typical of large-scale internal compromises but were not itemized publicly.

Operational Impact

Uber temporarily restricted or disabled access to several internal tools — including portions of its Slack workspace, internal engineering tools, and financial systems — while the incident was contained and credentials were rotated. Engineering teams were required to review and validate code repositories the attacker may have accessed, and security teams conducted an organization-wide credential and access review.

Reputation Damage

The breach generated substantial global media coverage, in part because the attacker communicated directly and publicly with security researchers and journalists, and because the intrusion appeared to grant near-total internal access rather than being confined to a single system. The apparent ease of the compromise — hardcoded admin credentials in a script — was widely cited in the security community as a cautionary example, which affected perceptions of Uber's internal security maturity independent of any customer data exposure.

Customer Impact

Uber stated that it found no evidence that riders', drivers', or couriers' account data (including trip history or payment details) across Uber, Uber Eats, or Uber Freight was accessed or exfiltrated. The direct customer-facing impact was therefore limited to indirect trust and reputational effects rather than confirmed personal data exposure, based on Uber's own disclosures.

Legal Impact

Uber notified U.S. federal law enforcement (including the FBI and Department of Justice) and cooperated with UK authorities investigating the Lapsus\$ group. In the United Kingdom, two individuals connected to Lapsus\$ were prosecuted for a series of intrusions that included the Uber breach; one defendant, an 18-year-old identified in court reporting as Arion Kurtaj, was convicted in August 2023 on multiple counts including unauthorized computer access and blackmail, and was later ordered into indefinite hospital detention after being found unfit to be sentenced conventionally due to a diagnosed condition. This legal outcome is separate from any regulatory enforcement action against Uber itself.

8. Lessons Learned

What the Organization Learned

The incident demonstrated that a single, well-executed social-engineering attempt against one contractor account can escalate into an organization-wide compromise if internal defenses assume that anyone who is already authenticated onto the VPN is inherently trustworthy. It also demonstrated that centralizing secrets in a PAM platform only reduces risk if access to that platform itself is tightly controlled and never bypassed through operational shortcuts, such as embedding credentials directly in automation scripts for convenience.

Security Improvements Reported or Recommended Following the Incident

- Moving away from simple push-based MFA approval toward number-matching MFA or phishing-resistant authentication methods (such as FIDO2 hardware security keys), which are much harder to approve accidentally or under social pressure.
- Reviewing and reducing standing VPN access so that contractor and employee accounts reach only the specific internal resources required for their role, rather than broad network-level access.
- Auditing internal scripts, repositories, and network shares for hardcoded credentials, and migrating automation workflows to use short-lived, dynamically issued credentials from the secrets vault instead of embedded static passwords.
- Strengthening security awareness training specifically around MFA-fatigue and impersonation tactics, since generic phishing training does not always cover push-notification social engineering.
- Increasing monitoring and alerting around anomalous PAM administrator logins and unusual internal network share access, which — had it been in place — could have shortened the time between compromise and detection.

9. Recommendations

The recommendations below are standard industry controls, each explained in terms of the specific failure point in this incident it would have addressed.

Multi-Factor Authentication (Phishing-Resistant)

Replacing simple push-approval MFA with number-matching MFA or hardware-based FIDO2 keys removes the ability of an attacker to gain access purely by exhausting a user's patience. This directly addresses the MFA-fatigue technique that provided the attacker's initial foothold in this incident.

Security Awareness Training

Regular, scenario-based training — including simulated MFA-fatigue and impersonation attempts — helps employees and contractors recognize and correctly reject sustained social-engineering pressure rather than approving a request simply to make it stop.

Patch Management

Although this specific incident did not stem from an unpatched vulnerability, disciplined patch management remains a foundational control, since it closes the software-based attack vectors most commonly paired with credential-based attacks in real-world intrusions, reducing the number of paths available to an attacker who does gain a foothold.

Endpoint Protection

Endpoint detection and response (EDR) tooling on contractor and employee devices helps detect the malware or unusual device activity that may precede credential theft, and can alert security teams earlier in the attack chain than waiting for the attacker to act on stolen credentials.

Network Monitoring

Continuous monitoring for anomalous behavior — such as an authenticated VPN session broadly scanning internal file shares, or a PAM administrator account logging in from an unusual location — would have offered an earlier detection opportunity than relying on the attacker's own self-disclosure.

Incident Response Plan

A well-rehearsed incident response plan, including predefined steps for rapid credential revocation, tool lockdown, and law-enforcement engagement, shortens the time between detection and containment and reduces the total scope of an incident, as reflected in Uber's own rapid credential-reset and lockdown actions following disclosure.

Regular Backups

While not central to this specific incident, maintaining tested, access-segregated backups remains essential general practice, ensuring that even if an attacker with broad internal access attempts to destroy or tamper with data, the organization retains a clean recovery point.

10. Conclusion

The 2022 Uber data breach is a widely studied example of how a single successful social-engineering attempt against a low-privilege external account can cascade into organization-wide compromise when internal controls assume too much trust once a user is inside the network perimeter. The incident did not require any custom malware or software exploit; it required patience, psychological pressure applied to one contractor, and a basic credential-hygiene failure in the form of hardcoded administrator credentials in an automation script. For a Cybersecurity Analyst Intern, the case illustrates a recurring theme across many real-world breaches studied in this internship: strong individual controls (MFA, PAM, VPN) can still fail collectively when they are not layered with the assumption that any single control might eventually be defeated. Uber's rapid public disclosure, credential rotation, and cooperation with law enforcement are also a useful reference point for what a disciplined incident response looks like once containment is underway.

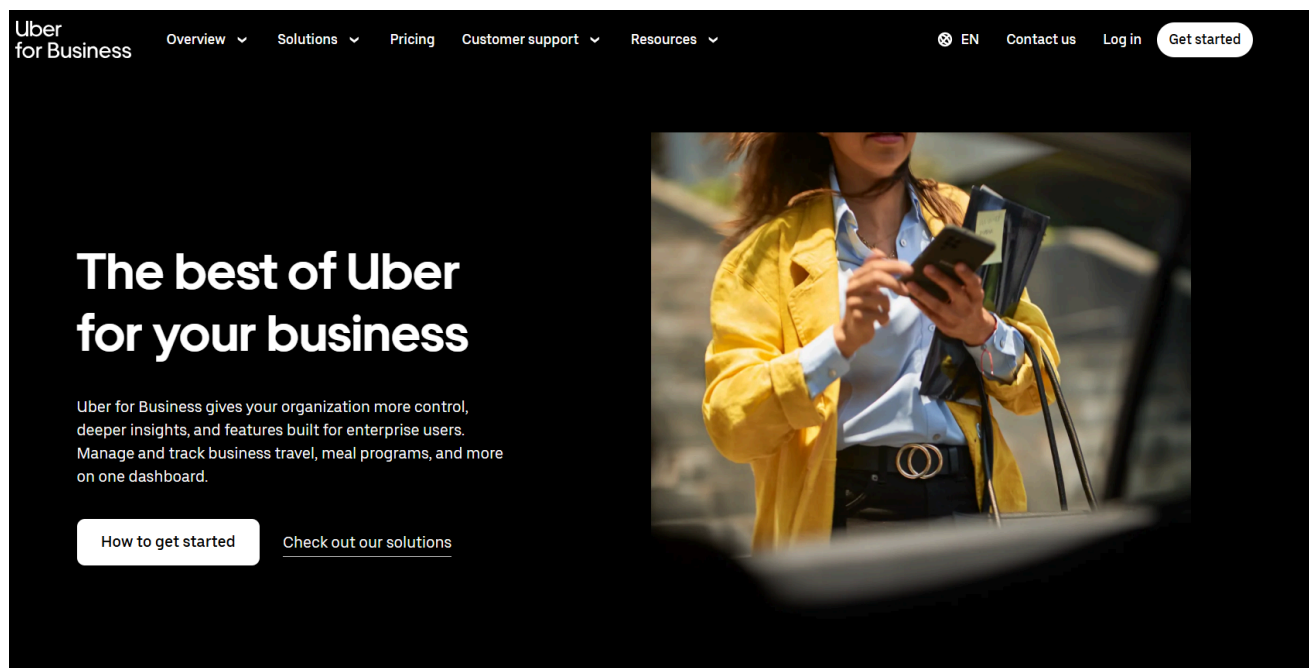
11. References

The following publicly available sources were used to compile this case study. All URLs should be verified as active at the time of submission.

- Uber Newsroom, official security update statements regarding the September 2022 incident.
- The New York Times, reporting on the Uber breach and the attacker's account of events.
- The Hacker News, "Uber Blames LAPSUS\$ Hacking Group for Recent Security Breach," September 2022.
- The Hacker News, "Two LAPSUS\$ Hackers Convicted in London Court for High-Profile Tech Firm Hacks," August 2023.
- BankInfoSecurity, reporting on the sentencing of Arion Kurtaj.
- CyberArk, "Unpacking the Uber Breach" (Red Team technical analysis).
- GitGuardian, "Uber Breach 2022" (analysis of hardcoded credential exposure).
- UpGuard, "What Caused the Uber Data Breach in 2022?"
- MITRE ATT&CK Enterprise Matrix, attack.mitre.org (technique reference for Section 6).
- Forbes, reporting on the arrest of the individual believed responsible for the Uber and Rockstar Games intrusions.

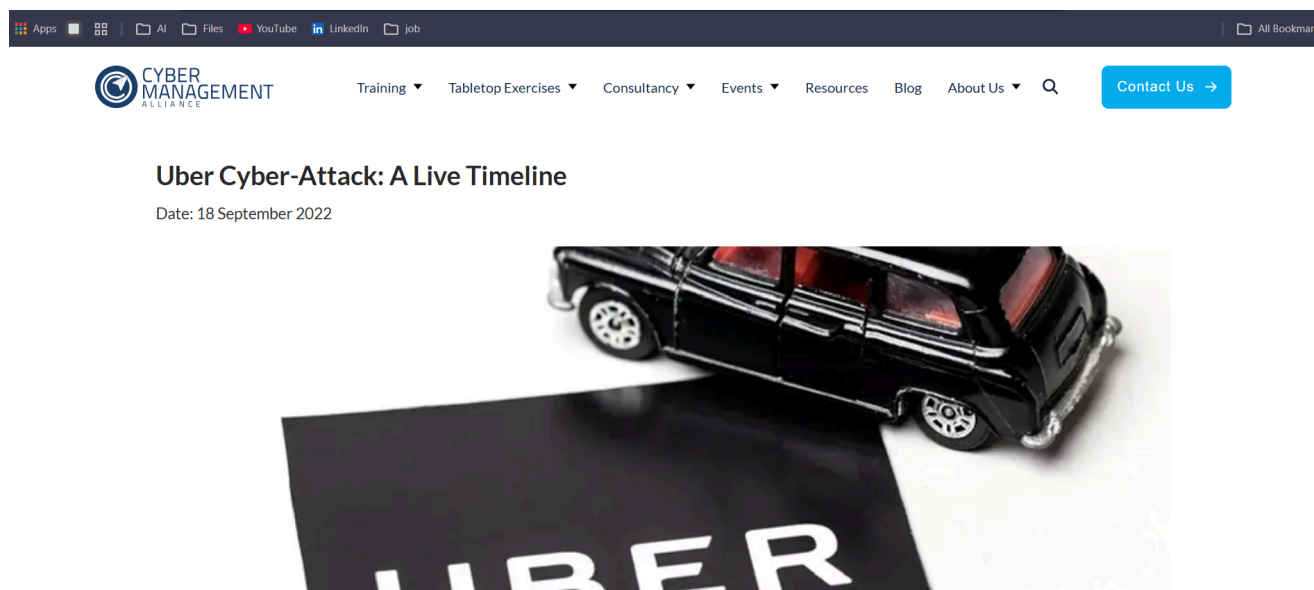
12. Evidence & Screenshots

Figure 1: Company Overview



Uber's corporate profile / public newsroom page showing company scale and business lines, for context (Section 2).

Figure 2: Attack Timeline



Uber needs no introduction so we'll skip that part and jump right into the big news - apparently it's been compromised by an 18-year old hacker!

<https://www.cm-alliance.com/cybersecurity-blog/uber-cyber-attack-crowdsourced-timeline>

Visual timeline diagram of the seven-stage attack chain reconstructed in Section 4, from initial access to containment.

Figure 3: News Report

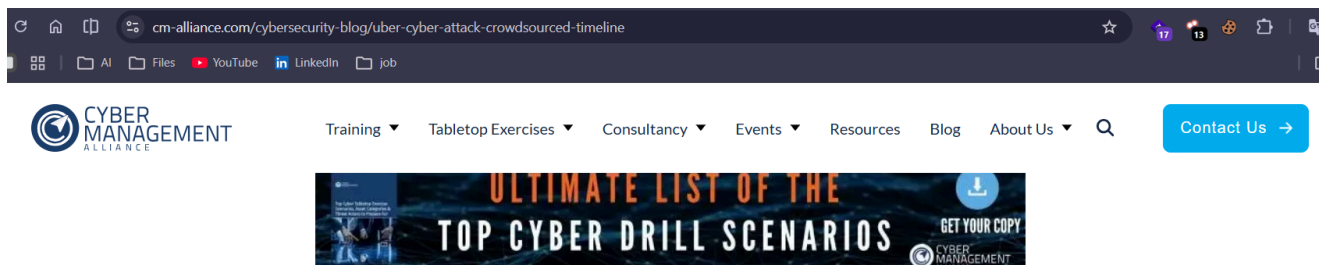


<https://thehackernews.com/2022/09/uber-claims-no-sensitive-data-exposed.html>

<https://www.cnbc.com/2022/09/16/uber-investigates-cybersecurity-incident-after-reports-of-a-hack.html>

Screenshot of a contemporaneous news article (e.g. The Hacker News or The New York Times) confirming Uber's public disclosure of the breach.

Figure 4: Impact Summary



Business Impact

16th September-2022: In its official update, Uber said: "We have no evidence that the incident involved access to sensitive user data (like trip history). All of our services including Uber, Uber Eats, Uber Freight, and the Uber Driver app are operational."

16th September-2022: According to *Bloomberg*, Uber shares fell 5.2% in pre-market trading in New York Friday.

16th September-2022: According to *BleepingComputer*, "The attacker downloaded all vulnerability reports before they lost access to Uber's bug bounty program. This likely includes vulnerability reports that have not been fixed, presenting a severe security risk to Uber. HackerOne has since disabled the Uber bug bounty program, cutting off access to the disclosed vulnerabilities. However, it would not be surprising if the threat actor had already downloaded the vulnerability reports and would likely sell them to other threat actors to cash out on the attack quickly."

Disclaimer: This document has been created with the sole purpose of encouraging discourse on the subject of cybersecurity and good security practices. Our intention is not to defame any company, person or legal entity. Every piece of information mentioned herein is based on reports and data freely available online. Cyber Management Alliance neither takes credit nor any responsibility for the accuracy of any source or information shared herein.

Summary graphic of the business impact areas covered in (financial, operational, reputational, customer, legal).

